

**НЕКОММЕРЧЕСКОЕ АКЦИОНЕРНОЕ ОБЩЕСТВО
«КАЗАХСКИЙ НАЦИОНАЛЬНЫЙ ПЕДАГОГИЧЕСКИЙ
УНИВЕРСИТЕТ ИМЕНИ АБАЯ»**



УТВЕРЖДЕНО

Решением Правления
НАО «Казахский национальный
педагогический университет
имени Абая»

от «11» 025 года
Протокол №
Председатель Правления - Ректор
Тілеп Б.А.



**Правила проведения внутреннего аудита информационной безопасности
Некоммерческого акционерного общества «Казахский национальный
педагогический университет имени Абая»**

Алматы, 2025



Оглавление

1 Общие положения.....	3
2 Нормативная основа.....	3
3 Порядок проведения аудита.....	4
4 Критерии оценки соответствия.....	5
5 Документация и отчетность.....	5
6 Обязанность.....	6
Приложение 1.....	7
Лист согласования.....	8

1 Общие положения

1.1 Настоящие Правила проведения внутренних аудитов информационной безопасности (далее - Правила) Некоммерческого акционерного общества «Казахский национальный педагогический университет имени Абая» (далее — Университет) разработаны в соответствии с требованиями законодательства и стандартов Республики Казахстан в области информационной безопасности.

1.2 Целью настоящих Правил является создание регламентированной процедуры проверки соответствия текущих процессов, систем и политик информационной безопасности установленным стандартам, нормативным требованиям РК и внутренним регламентам Университета.

1.3 В настоящих Правилах используются следующие основные термины и определения:

Информационная система (далее – ИС) – совокупность программно-аппаратных средств, баз данных и организационных мер, предназначенных для сбора, хранения, обработки, передачи и защиты информации в целях автоматизации процессов и поддержки деятельности организации;

Информационная безопасность (далее – ИБ) – состояние защищенности государственных информационных ресурсов и систем, обеспечение конфиденциальности, целостности и доступности информации;

Внутренний аудит ИБ – процесс систематической и независимой оценки состояния информационной безопасности, направленный на выявление уязвимостей, оценку рисков и эффективности действующих мер защиты данных и ИТ-инфраструктуры;

Руководитель аудиторской группы – ответственное лицо, назначенное для организации и управления процессом проведения аудита;

Аудиторская группа – коллектив уполномоченных специалистов, ответственных за планирование, проведение и документирование результатов внутреннего аудита информационной безопасности;

План-график планового аудита – расписание, устанавливающее последовательность и сроки проведения мероприятий в рамках планового аудита информационной безопасности.

2 Нормативная основа

Настоящий документ разработан в соответствии со следующими нормативно-правовыми актами и документами:

- Постановление Правительства Республики Казахстан от 20.12.2016г. №832 «Об утверждении единых требований в области информационно-коммуникационных технологий и обеспечения информационной безопасности»;

- Приказ Министра информации и коммуникаций Республики Казахстан от 13 июня 2018 года № 263. «Об утверждении Правил проведения аудита информационных систем».

3 Порядок проведения аудита

3.1 Целями проведения внутреннего аудита по ИБ являются:

- анализ рисков, связанных с возможностью осуществления угроз безопасности в отношении ресурсов ИС;
- оценка текущего уровня защищенности ИС;
- локализация узких мест в системе защиты ИС;
- оценка соответствия ИС существующим стандартам в области информационной безопасности;
- выработка рекомендаций по внедрению новых и повышению эффективности существующих механизмов безопасности ИС.

3.2 Объектом аудита является все компоненты IT-инфраструктуры, включая серверы, сети, системы защиты, программное обеспечение, базы данных и процессы обработки информации, связанные с обеспечением безопасности данных.

3.3 Внутренний аудит по ИБ можно подразделить на следующие виды проверок:

- аудит ресурсов информационных систем, корпоративной вычислительной сети с целью подготовки технического задания на проектирование и разработку системы защиты информации;
- аудит информационных систем, корпоративной вычислительной сети, после внедрения системы безопасности для оценки уровня её эффективности;
- профилактический регулярный аудит, направленный на приведение действующей системы безопасности в соответствие с требованиями нормативных правовых актов Республики Казахстан;
- аудит, предназначенный для систематизации и упорядочивания существующих мер защиты информации;
- аудит (служебное расследование) в целях расследования произошедшего инцидента, связанного с нарушением требований информационной безопасности;
- совместный аудит, проводимый с другими государственными органами Республики Казахстан.

3.4 Внутренний аудит по ИБ подразделяется на плановый и внеплановый.

3.5 Плановый аудит информационной безопасности проводится согласно утвержденному плану-графику планового аудита, который составляется ежегодно Офицером безопасности и утверждается приказом Руководства. Форма Плана-графика приведена в Приложении № 1 к настоящим Правилам.

3.6 На основании утвержденного Плана-графика внутреннего аудита формируются программы проведения конкретных проверок – программы аудита, которые составляются Офицером безопасности и утверждаются Руководством. Форма Программы аудита приведена в Приложении № 2 к настоящим Правилам.

3.6 Внеплановые аудиты могут проводиться в случае обнаружения инцидентов информационной безопасности, изменений в ИТ-инфраструктуре или по запросу Руководства.

3.7 Внутренний аудит по ИБ осуществляется в соответствии с порядком, представленным в Таблице 1.

Таблица 1 – «Этапы проведения аудита»

№	Этапы	Задачи
1	Подготовительный этап	Определить цели и задачи аудита. Сформировать команду аудиторов. Назначить ответственных лиц. Разработать график проведения аудита.
2	Сбор информации	Изучить документации (политики безопасности, протоколы, журналы событий). Провести интервью с ключевыми сотрудниками, ответственными за ИТ и безопасность. Анкетирование обычных сотрудников Университета. Сбор данных о текущих мерах защиты.
3	Анализ собранной информации	Анализ данных с целью выявления уязвимостей в системах и процессах, которые могут стать целью для атак.
4	Проверка соответствия законодательству и стандартам	Сравнение текущих процессов безопасности с установленными стандартами, политиками и нормативами РК.
5	Выработка рекомендаций	Рекомендации по устранению обнаруженных уязвимостей и улучшению существующих процессов и мер защиты.
6	Подготовка отчета	После выполнения программы аудита Руководитель группы по аудиту, совместно с группой аудиторов оформляют отчет по аудиту. Форма отчета по аудиту приведена в Приложении 3 к настоящим Правилам.

4 Требования к аудиторской группе

4.1 Для проведения внутреннего аудита ИБ формируется аудиторская группа.

4.2 Руководителем аудиторской группы назначается Офицер безопасности, который отвечает за организацию и контроль выполнения всех этапов аудита.

4.3 Аудиторская группа может включать как сотрудников Университета, так и внешних экспертов по информационной безопасности.

4.4 При определении состава аудиторской группы должны учитываться:

- цели, область аудита ИБ, критерий аудита и его ориентировочная продолжительность;

- общая компетентность и уровень квалификации аудиторской группы;
- необходимость исполнения принципов проведения аудита ИБ.

4.5 При проведении внутреннего аудита (планового и внепланового) члены аудиторской группы имеют право на:

- беспрепятственный допуск в служебные помещения проверяемых объектов;
- опечатывание предоставленных им служебных помещений проверяемых объектов, для обеспечения сохранности находящихся в них документов;
- беспрепятственный доступ к необходимой информации, находящейся в распоряжении Офицера безопасности, включая компьютерные системы, для осуществления внутреннего аудита, а также к документам, относящимся к предмету проверки;
- получение копий документов, подписанных соответствующим лицом и заверенных печатью;
- получение в пределах установленных законодательством записей, хранящихся в локальных вычислительных сетях и автономных компьютерных системах, а также получения расшифровки этих записей;
- получение от работников проверяемых участков устных и письменных объяснений по вопросам, возникающим в ходе проведения проверки.

5 Инструментальное обеспечение внутреннего аудита информационной безопасности

5.1 При проведении внутреннего аудита ИБ применяется соответствующее инструментальное обеспечение. Инструментальное обеспечение, используемое при аудите ИБ, включает средства автоматизации анализа выполнения требований ИБ и средства автоматизации оценки рисков.

5.2 Инструментальные средства автоматизации анализа выполнения требований ИБ (критериев аудита ИБ) должны позволять:

- автоматизировать процесс оценки степени выполнения требований ИБ с учетом их важности;
- оценивать эффективность различных вариантов защитных мер;
- автоматизировать процессы анализа идентифицированных и зафиксированных системами мониторинга ИБ, используемых в аудируемых структурных подразделениях, внештатных действий пользователей и инцидентов ИБ;
- генерировать документальные отчеты с результатами выполнения различных процедур.

5.3 Инструментальные средства автоматизации оценки рисков должны позволять:

- анализировать выполнение политики ИБ;

- оценивать риски с использованием принятых подходов и методик, утвержденных уполномоченным органом в области технической защиты информации;
- идентифицировать и оценивать варианты корректировок риска;
- вырабатывать рекомендации по методам и средствам снижения риска при сборе, обработке, хранении конфиденциальной информации;
- вырабатывать и предоставлять обоснования для выбора защитных мер;
- генерировать отчеты по результатам оценки.

6 Ответственность

6.1 Все участники внутреннего аудита информационной безопасности ИТ-инфраструктуры обязаны соблюдать конфиденциальность и не разглашать полученную информацию третьим лицам без предварительного разрешения.

6.2 Ответственные лица, проводящие аудит, должны иметь соответствующую квалификацию и опыт в области информационной безопасности, а также следовать процедурам и методологии аудита, установленным в Университете.

6.3 Ответственность за соблюдение сроков проведения внутреннего аудита ИБ несет Руководитель аудита.

6.4 Результаты аудита должны быть представлены Руководству с подробными отчетами и рекомендациями по улучшению информационной безопасности.

6.5 Руководство должно рассмотреть заключительный отчет и принять меры по исправлению выявленных проблем и реализации рекомендаций.

Приложение 1 к
Правилам проведения внутреннего
аудита информационной безопасности
ИТ инфраструктуры НАО «Казахский
Национальный педагогический университет
имени Абая»

План-график внутренних аудитов на _____ год

Наименование подразделений	Объект аудита	Дата предыдущего аудита	Отметка о плановой и фактически проведенной проверке											
			январь	февраль	март	апрель	май	июнь	июль	август	сентябрь	октябрь	ноябрь	декабрь

Примечание: В случае возникновения в подразделениях сбойных ситуаций, неучтенных опасностей и рисков проводится дополнительная внеплановая проверка.
Условные обозначения:



- плановая проверка



- фактически проведенная проверка

Руководитель аудиторской группы _____

Приложение 2 к
Правилам проведения внутреннего
аудита информационной безопасности
IT инфраструктуры НАО «Казахский
Национальный педагогический
университет имени Абая»

«УТВЕРЖДАЮ»

Должность, Ф.И.О. (при его наличии), подпись
« ____ » ____ 20 ____ года

Программа аудита № _____

1. Наименование структурного подразделения: _____
2. Цель аудита _____
3. Сроки проведения аудита _____
4. Задачи аудита _____
5. Состав группы: _____
6. Перечень нормативных документов: _____
7. Дата представления отчета _____
8. Отчет печатать в _____ экземпляр.

Руководитель аудиторской группы	_____	_____	_____
	(подпись)	(дата)	(Ф.И.О. (при его наличии))
Аудиторы	_____	_____	_____
	(подпись)	(дата)	(Ф.И.О. (при его наличии))
	_____	_____	_____
	(подпись)	(дата)	(Ф.И.О. (при его наличии))

«СОГЛАСОВАНО»

Руководитель проверяемого
структурного подразделения

_____	_____	_____	_____
(подпись)	(дата)	(Ф.И.О. (при его наличии))	

Приложение 3 к
Правилам проведения внутреннего
аудита информационной безопасности
IT инфраструктуры НАО «Казахский
Национальный педагогический
университет имени Абая»

«УТВЕРЖДАЮ»

Должность, Ф.И.О. (при его наличии), подпись
« ____ » ____ 20 ____ года

Отчет о внутреннем аудите информационной безопасности

№ по плану аудитов

1. Наименование структурного подразделения _____
2. Руководитель структурного подразделения _____
3. Руководитель аудиторской группы _____
4. Аудиторы _____
5. Дата аудита _____
6. Раздел/ документ (ы), на соответствие которому (ым) проводится внутренний аудит _____

7. РЕЗУЛЬТАТЫ АУДИТА:

Количество выявленных несоответствий _____
Количество предложений _____

8. ЗАКЛЮЧЕНИЕ ПО РЕЗУЛЬТАТАМ АУДИТА:

Деятельность _____ удовлетворяет (не удовлетворяет)
наименование подразделения _____
установленным требованиям _____
Корректирующие мероприятия (план) _____

Необходимость повторного внутреннего аудита: ДА/НЕТ по документу

Составил _____

Руководитель аудиторской группы _____
(подпись, дата) (Ф.И.О. (при его наличии))

ЛИСТ ОЗНАКОМЛЕНИЯ

[illegible]